MANAGEMENT DECISION · GENERAL EDITION

Security proposal for management

One shared foundation. Three complete protection packages.

Maximum 100 administrators | 2FA in every option | No additional servers to operate

Choose the common foundation plus one proposal. These are design recommendations, not implemented controls or a full cost quotation. Each item is a short list of points, and every point links to its supporting evidence.

Strategy citations stay in this site and provide a return link. External sources open a new tab. In PDF and Markdown exports, strategy citations open the published general strategy so they work wherever the files are saved.

Contents

Common foundation

Proposal 1 · Lean AWS

Proposal 2 · AWS edge

Proposal 3 · Existing edge

Budget worksheet

Q&A worksheet

Protect the organization and every AWS account

01 Named owners, segregation of duties and a control register

- Name owners for AWS administration, security incidents, billing and the application in a RACI that covers the platform team, the application team, the steering committee, the emergency authority and the edge vendor. [Strategy: Ownership and approvals]
- The production approver is never the author of the change. [Strategy: Ownership and approvals]
- Keep a control register as the basis for the ISO 27001 Statement of Applicability, with evidence that each control works. [Strategy: Ownership and approvals]
- Give every accepted exception an approver and an expiry date, and review the risk register quarterly and after every drill. [Strategy: Platform compensates]
- Report monthly to the steering committee with the strategy's metrics, most of which come straight from Security Hub, AWS Config, Inspector and GuardDuty. [Strategy: Metrics and reporting]

02 One AWS Organization with purpose-built accounts

- Create an AWS Organization whose management account holds only Organizations, consolidated billing and IAM Identity Center, never workloads. [Strategy: Account security]
- Put the security-tooling, log-archive and backup accounts in a Security organizational unit, and separate production and development accounts in a Workloads unit. [AWS multi-account guidance]
- Delegate GuardDuty, Security Hub, Inspector, AWS Config aggregation, IAM Access Analyzer and Macie to the security-tooling account. [Strategy: Account security]
- Build the structure with Terraform in a separate organization pipeline that requires two-person approval. [Strategy: Account security]
- Move production into its own account before go-live if the timeline allows, because migrating it later is harder. [Strategy: Production account decision]

03 Service control policies that no administrator can bypass

- Deny leaving the organization and deny every Region except the home Region, exempting only global services such as IAM, Route 53, CloudFront and Shield. [Strategy: Guardrail policies]
- Deny disabling CloudTrail, AWS Config, GuardDuty, Security Hub, Inspector, Macie or Access Analyzer, except for the security automation role. [Strategy: Security services locked]
- Deny creating IAM users, access keys or console passwords, and deny all root-user actions in member accounts. [Strategy: No permanent keys]
- Protect the platform roles and the log-archive buckets and keys, and stop anyone weakening EBS encryption by default or S3 Block Public Access. [Strategy: Encryption locked]
- Allow internet gateway, peering, route table and NACL changes only through the platform pipeline role, and make human roles read-only in production. [Strategy: Read-only humans in production]

- Test every policy in development for a week with IAM policy simulation before attaching it to production, and alert on any policy change. [Strategy: Account security]

04 Resource control policies: a data perimeter around the organization

- Attach RCPs at the root that deny access to S3, KMS, Secrets Manager, SQS, STS and CloudWatch Logs from identities outside our organization, unless the caller is an AWS service. [Strategy: Data boundaries]
- Deny requests to S3, KMS, Secrets Manager and SQS that are not encrypted in transit. [Strategy: TLS only]
- Deny AWS services acting on our resources on behalf of another organization, which blocks confused-deputy abuse. [Strategy: Confused-deputy protection]
- Inventory external access with IAM Access Analyzer first, and list each legitimate integration, such as an edge vendor's log-delivery role, as an explicit exception. [Strategy: Vulnerability and access analysis]

05 Secure defaults enforced by declarative policies and account baselines

- Turn on all four S3 Block Public Access settings in every account and lock them with an SCP. [Strategy: Storage protection]
- Turn on EBS encryption by default with a customer managed KMS key, also locked by SCP. [Strategy: Disk encryption]
- Block public AMIs and snapshots with a declarative policy at the root. [Strategy: Secure defaults]
- Enable VPC Block Public Access everywhere except the production public load balancer and NAT subnets. [Strategy: VPC public-access block]
- Require IMDSv2 with a hop limit of one, disable serial console access, and allow machine images only from Amazon, the CIS publisher and our own accounts. [Strategy: Instance safeguards]
- Add the AI services opt-out policy, a tag-driven organization backup policy and a tag policy for environment, owner, data-class and component, applied by one Terraform module and checked by Security Hub. [Strategy: Required tags]

06 Named identities through IAM Identity Center with mandatory MFA

- Every person gets a named login through IAM Identity Center federated to the client's identity provider, with Microsoft Entra ID recommended. [Strategy: Identity provider decision]
- If Entra ID is unavailable, Identity Center's own directory is the fallback with a manual joiner-mover-leaver process. [Strategy: Identity provider decision]
- MFA is required on every sign-in, enforced in Identity Center when it holds the users or by an Entra ID authentication strength when federated. [Strategy: Mandatory 2FA]
- Super administrators and governing-organization administrators use FIDO2 security keys or passkeys, and SMS and email codes are off. [Strategy: Mandatory 2FA]
- Permission sets for Viewer, Operator, Deployer and Auditor replace IAM users, with console sessions capped at eight hours and administrator sets at one hour. [Strategy: Identity controls]
- Accounts are disabled after 45 days without sign-in, and all access is recertified every quarter. [Strategy: Administrator inventory]

07 Management account, root users and break-glass

- SCPs and RCPs never apply to the management account, so it holds no workloads and is protected by process and detection. [AWS management account guidance]
- At most two named administrators enter it, through Identity Center with security keys, and any sign-in raises a P1 alert. [Strategy: Account security]
- Its root user has two hardware MFA keys in separate safes under a sealed-envelope custodian process, no access keys and a root-usage alarm. [Strategy: Identity controls]
- Centralized root access deletes root credentials from every member account, and new accounts are created without them. [Strategy: Root protection]
- Two named, sealed break-glass identities exist; every use pages the security owner and triggers a post-use review. [Strategy: Identity controls]

08 An immutable, organization-wide audit trail

- One organization CloudTrail covers all accounts and Regions with log file validation and KMS encryption, delivered to the log-archive account. [Strategy: Audit trail]
- AWS Config records every resource type, with an organization aggregator in the security-tooling account. [Strategy: Configuration recording]
- Security and audit logs sit in S3 with Object Lock in compliance mode: one year readily available plus six years in Glacier, with no human write access. [Strategy: Log retention]
- Operational logs are kept 30 to 90 days and access logs one year. [Strategy: Log retention]
- Load balancer, Envoy, edge, VPC Flow, EKS audit, pgaudit and administrator-access logs all go to the same archive. [Strategy: Logging]
- Application audit events record who changed which guidance object, from where and when. [Strategy: Logging]

09 Managed detection with alert-only routing

- GuardDuty runs organization-wide with the S3, EKS audit and runtime, RDS and Malware Protection plans. [Strategy: Threat detection]
- Security Hub central configuration applies the CIS AWS Foundations and Foundational Security Best Practices standards to every account. [Strategy: Security Hub standards]
- Inspector scans EC2, ECR and Lambda, and IAM Access Analyzer reports external and unused access. [Strategy: Vulnerability and access analysis]
- Security Hub automation rules suppress accepted exceptions and raise production severity before EventBridge routes findings to one SNS topic per tier. [Security Hub automation rules]
- P1 pages an on-call phone 24/7, P2 goes to chat through Amazon Q Developer in chat applications plus email, and P3 goes into a weekly digest. [Strategy: Incident alerts]
- P1 targets acknowledgement in 15 minutes and containment in one hour, every alert carries a runbook link, and the pipeline is tested monthly with GuardDuty sample findings. [Strategy: Incident alerts]

10 Backups that an attacker or administrator cannot delete

- An AWS Backup plan gives the production PostgreSQL database point-in-time recovery of at least seven days and daily snapshots kept for 35 days. [Strategy: Data protection]
- Copies go to a vault in the separate backup account. [Strategy: Data protection]
- AWS Backup Vault Lock in compliance mode means not even an administrator can delete those copies early. [AWS backup protection]
- An organization backup policy applies the plan by tag, so new databases are covered automatically. [Strategy: Backup policy]
- A restore from the backup account runs every quarter, recording recovery time and data loss for the business to confirm. [Strategy: Metrics and reporting]

11 Changes only through reviewed code and keyless pipelines

- Account, network and cluster changes come only from reviewed Terraform and Argo CD configuration. [Strategy: Secure delivery]
- GitHub Actions assumes AWS roles through an IAM OIDC provider whose trust is pinned to repository, branch, environment and workflow, with no stored access keys. [Strategy: Deployment identity]
- Every role the pipeline creates carries a permission boundary. [Strategy: Deployment identity]
- The GitHub organization requires SSO and MFA, branch protection with signed commits, CODEOWNERS on infrastructure and workflow files, required reviewers for production and no self-approval. [Strategy: Secure delivery]
- Any IAM user, access key, administrator policy, SCP or permission boundary changed outside the pipeline alerts at P2, or P1 in production. [Strategy: Identity-change alerts]

12 Cost alarms as a security signal

- AWS Budgets in every account and Cost Anomaly Detection notify the billing and security owners as P2 alerts. [Cost Anomaly Detection]
- A sudden compute spike is often the first sign of crypto-mining after a credential leak. [Strategy: Cost alerts]
- Review actual monthly spend against the worksheet in this proposal, including detection, logs, backups, licences and staff time. [Strategy: Cost alerts]
- Budget alerts warn people but do not cap spending. [Cost Anomaly Detection]

13 Twelve go-live gates with evidence, not dates

- Launch waits for twelve security gates, each with evidence rather than a date. [Strategy: Launch tests]
- Gates include working administrator login and role-based authorization, a public API reduced to an allow-list, and signed images enforced in the cluster. [Strategy: Gate: administrator login]
- AWS WAF must be in BLOCK after a clean seven-day COUNT period, logs must be immutable, and Security Hub must score 95 percent or better. [Strategy: Gate: WAF blocking]
- An independent penetration test must pass with no open Critical or High findings after retest. [Strategy: Gate: penetration test]

- A surge and DDoS drill with 500,000 simulated users must prove failover to the emergency page. [Strategy: Gate: surge drill]
- Data retention, residency and the DPIA must be signed off, and the steering committee sees the evidence for every gate. [Strategy: Gate: retention and residency]

Start with the lowest-complexity AWS package

01 Best fit and trade-off

- Choose this package when the public load balancer, with AWS WAF and the included Shield Standard protection, passes the 500,000-user surge and DDoS drill on its own. [AWS DDoS protection]
- It has the fewest moving parts and the lowest fixed cost, but every public request reaches the AWS Region directly. [Strategy: Outage under surge]
- There is no edge cache and no edge-served failover page, so the fallback depends on DNS failover. [Route 53 DNS failover]
- The strategy rates outage under surge as a Critical risk, so this package must disprove it in testing before approval. [Strategy: Outage under surge]

02 Public entry: Application Load Balancer, AWS WAF and Shield Standard

- An AWS WAF web ACL runs in BLOCK on the internet-facing Application Load Balancer. [Strategy: Web attack protection]
- It uses the AWS managed Core, Known Bad Inputs, SQL database, Linux and Admin Protection rule groups. [Strategy: Core rule set]
- The IP reputation and Anonymous IP lists work here because no proxy sits in front of the load balancer. [AWS WAF IP reputation groups]
- Rate-based rules use separate thresholds for the position write path, geo and routing lookups and site assets, set high for carrier-grade NAT and preferring Challenge over Block on reads. [Strategy: Rate limits]
- A positive allow-list returns 404 for everything except the listed public methods and paths. [Strategy: Public route allow-list]
- Shield Standard covers common network and transport floods at no charge; Shield Advanced at USD 3,000 per month is not assumed. [AWS Shield pricing]

03 Location checks without blocking emergency readers

- Public reads are never geo-blocked, because home-routed roaming makes visitors inside the service area appear with foreign IP addresses. [Strategy: Web attack protection]
- Requests are labelled by country with a Count rule, and traffic from outside the service country gets stricter rate limits. [Strategy: Web attack protection]
- Position writes are validated in the application with PostGIS: coordinates outside the service-area polygon, implausible speeds and out-of-range timestamps are rejected. [Strategy: Fake check-ins]
- AWS WAF blocks anonymizers and hosting providers on the write path only. [Strategy: Visitor reputation]

- Administrator location is enforced at the identity provider and in the Verified Access policy, never at the public WAF. [Strategy: Location controls]

04 Administrator console: Verified Access, Identity Center and application RBAC

- One AWS Verified Access HTTP endpoint fronts the existing internal administrator load balancer that serves the Angular console and the admin gateway. [Strategy: Administrator access]
- It uses a non-descriptive hostname on a domain separate from the public site, with a public ACM certificate. [Strategy: Low-visibility name]
- IAM Identity Center with mandatory MFA is the trust provider, and the AWS WAF web ACL is attached to the Verified Access instance. [Strategy: Administrator web firewall]
- Group-based Cedar policies grant the console and deny everything not listed, and client IP addresses are restricted to the service country with a time-boxed exception process. [Strategy: Group access policies]
- Sessions last eight hours, and a user disabled at the identity provider loses access when the session ends. [Strategy: Short sessions]
- The admin gateway verifies the signed user-context token on every request, and the application still enforces its own OIDC login and role-based authorization. [Strategy: Application identity]

05 Engineering access: two TCP endpoints and CloudShell, no jump server

- Super administrators use two Verified Access TCP endpoints through the Connectivity Client. [Strategy: Administrator access]
- A network CIDR endpoint covers only the subnets holding the EKS control-plane interfaces on port 443, and Argo CD is reached by kubectl port-forward. [Strategy: Least-privilege endpoints]
- An RDS endpoint targets RDS Proxy, never the database instance, and security groups admit only the Verified Access endpoint. [Strategy: Least-privilege endpoints]
- CloudShell VPC environments, at no additional charge, are the break-glass and Linux path, because the Connectivity Client runs only on Windows and macOS. [Strategy: Serverless break-glass]
- CloudShell sessions end after 20 to 30 minutes idle, so it is a recovery path, not a daily tool. [CloudShell limits]
- The new path runs in parallel with the Client VPN for two weeks with a written rollback before the VPN endpoint is removed. [Strategy: Access without VPN]

06 Inside the VPC: private EKS, segmented namespaces and controlled egress

- The EKS API endpoint stays private, reachable only from inside the VPC or through the Verified Access endpoint. [Strategy: Access options]
- Public and administrative workloads run in separate namespaces under Pod Security Admission restricted. [Strategy: Workload identities]
- Default-deny NetworkPolicies block all traffic between the public and admin namespaces in both directions, and each gateway accepts traffic only from its own Envoy. [Strategy: Workload identities]

- Exact-match HTTPRoutes replace the broad proxied API prefix, and the Swagger, API-docs and actuator paths are denied at the WAF. [Strategy: Public route allow-list]
- The default VPC is deleted, and VPC endpoints for S3, ECR, STS, Secrets Manager, KMS and CloudWatch Logs keep traffic inside AWS. [Strategy: No default networks]
- Remaining egress passes through AWS Network Firewall with a domain allow-list, and service-to-service traffic moves to mutual TLS through Envoy or an ambient mesh. [Strategy: Outbound restrictions]

07 One identity per workload, one login per service

- EKS Pod Identity maps each Kubernetes service account to its own IAM role: web, public gateway, devices, geometry, routing, console, admin gateway, backend and migration. [Strategy: Workload identities]
- Each role is scoped to its own Secrets Manager secret and KMS key, and automatic token mounting is off. [Strategy: Workload identities]
- The single superuser database login is replaced by a non-login owner role and a migration role used only by the Flyway job. [Strategy: Database permissions]
- The public devices service, the public geometry service and the admin backend each get their own login with only the table rights they need. [Strategy: Database permissions]
- Named DBA roles use IAM authentication, and the master account is reserved for break-glass. [Strategy: Database permissions]
- Each database user has its own Secrets Manager secret behind RDS Proxy, with connection limits, statement timeouts, forced TLS, and an alert on any owner or master login. [Strategy: Database anomaly alert]

08 Data protection and minimization

- Customer managed KMS keys per environment use split key policies and yearly rotation, and an SCP denies key deletion except through break-glass. [Strategy: Data protection]
- RDS stays Multi-AZ with deletion protection and pgaudit, and secrets are mounted from Secrets Manager through the CSI driver. [Strategy: Data protection]
- Raw location samples are deleted 30 days after an event closes, and only aggregates by area and time are kept. [Strategy: Data retention]
- The device email field is removed and device identifiers rotate for each event. [Strategy: Data retention]
- A DPIA is run and a privacy notice published before launch. [Strategy: Data protection]
- Photos enter only through the admin plane with presigned S3 upload URLs, are scanned by GuardDuty Malware Protection for S3, and are served from a bucket that is never public. [Strategy: Photo upload decision]

09 Hardened images, signed releases and admission control

- Every Java service is a multi-stage image on a hardened Eclipse Temurin 17 JRE base from Docker Hardened Images, with Amazon Corretto as the fallback. [Strategy: Container protection]
- Base images are pinned by digest and mirrored into ECR through a pull-through cache, so nodes pull only from ECR. [Strategy: Container protection]

- Containers run as a non-root numeric user with a read-only root filesystem, all capabilities dropped and no debug agent. [Strategy: Container protection]
- SBOM, provenance, Trivy and Inspector gates, cosign signing and immutable tags stay as they are. [Strategy: Secure delivery]
- Kyverno moves to Enforce: only signed images from the production ECR registry, no privileged pods, no root user, and the debug port denied. [Strategy: Secure delivery]
- Images are rebuilt weekly, Critical vulnerabilities are patched within seven days or 48 hours with a public exploit, and SAST, dependency review, secret scanning and DAST block the pipeline. [Strategy: Application security]

10 Detection, response and the emergency fallback in this package

- P1 detections page the on-call responder: guidance changed outside a change window, the site or emergency page unreachable, a blocked path reached at the origin, or a GuardDuty attack sequence. [Strategy: Incident alerts]
- Synthetic canaries in two or more locations watch the public site and the emergency page. [Strategy: Availability alert]
- The signed static emergency page is published to S3 as the strategy requires. [Strategy: Emergency fallback]
- With no edge cache, the switch to that page uses Route 53 health checks and DNS failover. [Route 53 DNS failover]
- S3 website endpoints do not support HTTPS, so the drill must prove the fallback over HTTPS: either a minimal CloudFront distribution for the emergency page or a written acceptance of the gap. [S3 website endpoints]

11 Cost checkpoint, not a complete quote

- One Verified Access web application at USD 0.27 per hour plus two TCP endpoints at USD 0.20 per hour cost about USD 489 per month at 730 hours. [Verified Access pricing]
- An AWS WAF example of one web ACL and ten billable rule entries adds USD 15 per month plus USD 0.60 per million inspected requests. [AWS WAF pricing]
- The administrator web ACL is priced separately, while Shield Standard and IAM Identity Center add no charge. [Identity Center pricing]
- Confirm deployment-Region rates and Verified Access availability in the console before approval. [Strategy: Access options]
- The common detection, logging, backup and labour allowances in the worksheet are planning estimates, not quotes. [Strategy: Access options]

12 What the team still owns

- No jump server, proxy, connector or monitoring server is added. [Strategy: Access options]
- The platform team still operates the EKS cluster, the CIS Ubuntu nodes rebuilt monthly, the Terraform layers, Kyverno and Argo CD. [Strategy: Shared responsibility]
- The application team still owns the Phase 12 fixes, including login, authorization and the devices split. [Strategy: Shared responsibility]
- The team tunes WAF rules after the COUNT period, maintains Cedar policies and Connectivity Client updates, and runs the incident playbooks. [Strategy: Responsibilities]

- The staged migration away from the current edge vendor and the Client VPN is also the team’s work. [Strategy: Access without VPN]

---

13 Management approval condition

- Approve only if the drill with 500,000 simulated users keeps the public application and the HTTPS emergency fallback usable with the load balancer exposed directly. [Strategy: Gate: surge drill]
- An external scan must confirm the admin and device-list paths return 404 or 403. [Strategy: Gate: public allow-list]
- If the drill fails, or caching in Proposal 2 is cheaper than scaling the cluster beyond its four-node cap, choose Proposal 2 rather than removing security controls. [Strategy: Outage under surge]

Add a managed edge for a surge-heavy public service

01 Best fit and trade-off

- Choose this package when absorbing the surge at a global edge is worth a managed delivery layer. [CloudFront pricing]
- Amazon CloudFront sits in front of the public load balancer, AWS WAF is evaluated at the edge, Shield Standard is included, and administrators use the same Verified Access path as Proposal 1. [Strategy: Administrator access]
- It stays AWS-only with no server to run and adds the edge-served emergency page the strategy calls for. [Strategy: Emergency fallback]
- Its value depends on measured traffic and on what can safely be cached. [CloudFront pricing]
- The residency decision must accept that public content is served from edge locations worldwide. [Strategy: Residency]

02 Public entry: CloudFront, AWS WAF at the edge and a locked origin

- An AWS WAF web ACL on the CloudFront distribution applies the Core, Known Bad Inputs, SQL database, Linux and Admin Protection managed rule groups. [Strategy: Web attack protection]
- The IP reputation and Anonymous IP lists work at the edge because CloudFront sees the real client. [AWS WAF IP reputation groups]
- Rate-based rules per path and the public route allow-list are enforced at the edge. [Strategy: Rate limits]
- The load balancer security group admits only the AWS-managed prefix list for CloudFront origin-facing servers. [AWS origin protection]
- A secret origin custom header, checked by a listener rule or the origin web ACL, stops anyone bypassing the edge. [AWS origin protection]
- The origin web ACL stays in BLOCK as a second layer, reads the client address from the forwarded IP header, and any blocked path reached at the origin alerts at P1. [Strategy: Origin bypass alert]

03 Cache public content, never private responses

- CloudFront caches site assets, the self-hosted map tiles once adopted, and the signed emergency page using custom caching rules. [CloudFront cache keys]
- The position write path, administrator traffic and anything carrying personal data are excluded from the cache key and the cache. [CloudFront cache keys]
- The publishing procedure defines how fast changed guidance must appear and uses CloudFront invalidations to enforce it. [CloudFront invalidation]
- An emergency update is rehearsed so the cache can never serve dangerously outdated instructions. [Strategy: Guidance integrity]

- An origin group makes the application primary and the S3 emergency page secondary, so GET requests fail over at the edge when the origin errors or times out. [CloudFront origin failover]

04 Location checks with the real client visible at the edge

- CloudFront geographic restrictions are not used on public reads, because they block whole countries and roaming visitors inside the service area appear foreign. [CloudFront geographic restrictions]
- The edge web ACL labels requests by country and applies stricter rate limits outside the service country. [Strategy: Web attack protection]
- Position writes are validated in the application with the PostGIS polygon, speed and timestamp checks. [Strategy: Fake check-ins]
- Anonymizers and hosting providers are blocked on the write path at the edge, where AWS WAF sees the real client address. [Strategy: Visitor reputation]
- Administrator location is enforced at the identity provider and in the Verified Access Cedar policy, with MFA as the primary control. [Strategy: Location controls]

05 Administrator console: Verified Access, Identity Center and application RBAC

- The administrator console stays entirely off the CloudFront distribution. [Strategy: Administrator hostname]
- One Verified Access HTTP endpoint fronts the internal administrator load balancer on its own low-visibility domain with a public ACM certificate. [Strategy: Low-visibility name]
- IAM Identity Center with mandatory MFA is the trust provider, and the AWS WAF web ACL is attached to the Verified Access instance. [Strategy: Administrator web firewall]
- Group-based Cedar policies grant the console to the location, governing-organization and super administrator groups, with eight-hour sessions. [Strategy: Group access policies]
- The admin gateway verifies the signed user-context token on every request. [Strategy: Application identity]
- Sign-ins from unexpected countries or hours alert at P2; changes to policies, trust providers or the web ACL, MFA resets, and administrators created outside the inventory alert at P1. [Strategy: Access logging]

06 Engineering access: two TCP endpoints and CloudShell

- Super administrators reach the private EKS API through a Verified Access network CIDR endpoint on port 443 and RDS Proxy through a Verified Access RDS endpoint. [Strategy: Least-privilege endpoints]
- Both use the Connectivity Client, and security groups admit only the Verified Access endpoint. [Strategy: Least-privilege endpoints]
- CloudShell VPC environments are the break-glass path when Verified Access or the identity provider fails during an event, reaching the EKS API, RDS Proxy and the admin gateway from inside the VPC. [Strategy: Serverless break-glass]
- Confirm that Verified Access and CloudShell VPC environments are offered in the deployment Region. [Strategy: Administrator access]

- The Client VPN stays until two weeks of parallel running are complete. [Strategy: Access without VPN]

07 Inside the VPC: the same segmentation as Proposal 1, plus origin isolation

- The private EKS endpoint, separate public and admin namespaces under Pod Security Admission restricted, and default-deny NetworkPolicies apply exactly as in Proposal 1. [Strategy: Workload identities]
- Exact-match public HTTPRoutes, VPC endpoints, a Network Firewall domain allow-list and mutual TLS between services apply as well. [Strategy: Network protection]
- VPC Block Public Access excludes only the public load balancer and NAT subnets. [Strategy: VPC public-access block]
- That load balancer accepts traffic only from the CloudFront prefix list, so the origin has no internet path except through the edge. [AWS origin protection]

08 One identity per workload, one login per service

- EKS Pod Identity maps each service account to its own IAM role scoped to one Secrets Manager secret and KMS key. [Strategy: Workload identities]
- Service account tokens are not mounted, and no application has a Role or RoleBinding in the cluster. [Strategy: Workload identities]
- The database uses a non-login owner, a Flyway migration role, and separate logins for the public devices service, the geometry service and the admin backend. [Strategy: Database permissions]
- Named DBA roles use IAM authentication, and every database user sits behind RDS Proxy with its own secret and connection limit. [Strategy: Database permissions]
- Separate connection pools stop a public flood from starving the administrator plane, and any owner or master login raises an alert. [Strategy: Database anomaly alert]

09 Data protection, minimization and what the edge may hold

- The KMS, Secrets Manager, RDS and backup controls are the same as Proposal 1. [Strategy: Data protection]
- Raw location samples are deleted 30 days after an event closes, the device email is removed, device identifiers rotate, and a DPIA and privacy notice are completed. [Strategy: Data retention]
- CloudFront caches and standard logs are checked to hold no personal data, and access logs are delivered to the log-archive bucket in the home Region. [CloudFront access logs]
- The residency decision records that cached public content is served from edge locations worldwide. [Strategy: Residency]
- CloudFront is a global service whose control-plane calls are made in us-east-1, so the Region guardrail lists it as an explicit exemption. [Strategy: Region safeguards]

10 Hardened images, signed releases and admission control

- Identical to Proposal 1: hardened Temurin JRE images pinned by digest and mirrored through an ECR pull-through cache. [Strategy: Container protection]
- Containers run non-root with a read-only filesystem and no debug agent. [Strategy: Container protection]
- Kyverno in Enforce verifies cosign signatures and allows only the production ECR registry. [Strategy: Secure delivery]
- Weekly rebuilds, seven-day Critical patching, and SAST, dependency review, secret scanning and DAST gates stay in the pipeline. [Strategy: Application security]
- Argo CD rollback remains the tested recovery for a bad release. [Strategy: Recovery]

11 Detection, response and the edge-served fallback

- The same P1 and P2 detections as Proposal 1 go to the on-call responder. [Strategy: Incident alerts]
- CloudWatch Synthetics canaries in two or more locations watch the public site and the emergency page through CloudFront. [CloudWatch Synthetics canaries]
- The emergency page lives in S3 behind the CloudFront origin group, so GET requests fail over at the edge without a DNS change. [Strategy: Emergency fallback]
- The DDoS playbook adds AWS Shield engagement and the pre-approved event-mode scale profile. [Strategy: Recovery]
- The surge drill rehearses the failover and an emergency guidance update, because CloudFront fails over only after a request to the primary origin fails and never for POST requests. [CloudFront origin failover]

12 Compare total edge cost before buying

- Budget about USD 489 per month for the Verified Access configuration, as in Proposal 1. [Verified Access pricing]
- CloudFront is priced pay-as-you-go or on a flat-rate plan. [CloudFront pricing]
- The Business plan at USD 200 per month includes AWS WAF, advanced DDoS protection, JavaScript challenge, custom caching rules and logging, with 125 million requests and 50 TB. [CloudFront pricing]
- Origin failover is listed only from the Premium plan at USD 1,000 per month, so the edge-served fallback needs Premium or pay-as-you-go, and the worksheet’s USD 200 starting value must be revised. [CloudFront pricing]
- Price with normal and emergency traffic forecasts, check what each plan bundles so WAF is not counted twice, and confirm all rates before approval. [CloudFront pricing]

13 What the team still owns and the approval condition

- AWS operates CloudFront, WAF, Shield and Verified Access. [Strategy: Access options]
- The team still maintains the application, the cluster and its policies, the caching and invalidation rules, the origin header secret and the administrator devices. [Strategy: Responsibilities]

- Approve only after the traffic model, an origin-bypass test proving that a direct connection to the load balancer is refused, and a cache-update test. [Strategy: Gate: origin accepts only the edge]
- The surge drill with edge failover and the residency review must also justify the cost over Proposal 1. [Strategy: Gate: surge drill]

Retain Imperva where its contract justifies the cost

01 Best fit and trade-off

- Choose this package when the existing Imperva cloud WAF, on a tier with bot management and a DDoS service-level agreement, avoids a costly migration or brings contractually valuable incident support. [Strategy: Imperva decision]
- AWS WAF at the origin and Verified Access for administrators apply exactly as in the other packages. [Strategy: Web attack protection]
- It is the architecture the strategy was written against. [Strategy: Network protection]
- It is the only package where IP reputation and anonymizer filtering for the public plane happen at a layer that sees the real client. [Strategy: Visitor reputation]
- Do not assume it is cheaper or more secure because it uses two vendors; obtain a written price and scope confirmation. [Strategy: Imperva decision]

02 Public entry: Imperva as the first filter

- Imperva’s default WAF Rules policy blocks SQL injection, cross-site scripting, illegal resource access and remote file inclusion; confirm nothing is set to Alert Only. [Strategy: Edge attack rules]
- Backdoor protection stays on Auto-Quarantine, and bot access control denies bad bots while allowing good ones. [Strategy: Backdoor protection]
- The DDoS detection threshold is tuned for 500,000 concurrent users so a real event does not look like an attack. [Strategy: DDoS threshold]
- An Imperva ACL allow-list permits only the public methods and paths, with rate rules per path. [Strategy: Public route allow-list]
- No CAPTCHA on public pages; a JavaScript challenge is used only on the position write path and only while under attack. [Strategy: Bot control]
- Confirm which rules, support, traffic allowances and emergency commitments the contract actually includes. [Strategy: Imperva decision]

03 Do not let attackers go around Imperva

- The origin load balancer security group admits only the Imperva prefix list. [Strategy: Origin guard]
- Origin mutual TLS is mandatory: the load balancer validates Imperva’s client certificate against an ALB trust store, so a direct connection is refused. [ALB mutual TLS]
- An AWS WAF web ACL in BLOCK on the origin applies the Core, Known Bad Inputs, SQL database, Linux and Admin Protection rule groups and the exact public route allow-list. [Strategy: Core rule set]
- The AWS IP reputation groups stay off at the origin, because they would only see Imperva’s addresses. [Strategy: Visitor reputation]

- Origin rate-based and geo rules read Imperva's client IP header, which is stripped if it arrives from anywhere else. [AWS WAF forwarded IP]
- Any request reaching a blocked admin or device-list path at the origin alerts at P1. [Strategy: Origin bypass alert]

04 Visitor checks where the real visitor is visible

- IP reputation, anonymizer and country checks happen at Imperva, because the origin sees only the proxy address. [Strategy: Visitor reputation]
- Public reads are labelled by country, not blocked, so roaming visitors inside the service area still receive guidance. [Strategy: Web attack protection]
- If hard country blocking is wanted anyway, it applies only to the write path through Imperva's ACL Block Countries, with the impact on roaming visitors recorded. [Imperva policies]
- The application validates every submitted coordinate against the service-area polygon. [Strategy: Fake check-ins]
- Administrator location is enforced at the identity provider and in Verified Access, not at the public edge. [Strategy: Location controls]

05 Administration stays off the public edge

- Administrators never pass through Imperva. [Strategy: Administrator hostname]
- One Verified Access HTTP endpoint fronts the internal administrator load balancer on a separate low-visibility domain. [Strategy: Low-visibility name]
- The AWS WAF web ACL on the Verified Access instance uses the IP reputation and Anonymous IP lists, which work there because no proxy is in front. [Strategy: Administrator web firewall]
- IAM Identity Center with mandatory MFA is the trust provider, Cedar policies grant the console per group, and sessions last eight hours. [Strategy: Mandatory 2FA]
- The admin gateway verifies the signed user-context token, and the application keeps its own OIDC login and role-based authorization. [Strategy: Application identity]

06 Engineering access without a server to maintain

- Two Verified Access TCP endpoints serve super administrators through the Connectivity Client: a network CIDR endpoint for the EKS API on port 443 and an RDS endpoint targeting RDS Proxy. [Strategy: Administrator access]
- Argo CD is reached by kubectl port-forward over the EKS API. [Strategy: Administrator access]
- CloudShell VPC environments cover break-glass and Linux users at no additional charge. [Strategy: Serverless break-glass]
- The Client VPN is removed only after two weeks of parallel running with a written rollback. [Strategy: Access without VPN]

07 Contain attacks after the public boundary

- The private EKS endpoint, public and admin namespaces under Pod Security Admission restricted, and default-deny NetworkPolicies apply as in Proposal 1. [Strategy: Workload identities]
- Exact-match HTTPRoutes and CIS-hardened NGINX apply as well. [Strategy: Public route allow-list]

- VPC endpoints for S3, ECR, STS, Secrets Manager, KMS and CloudWatch Logs plus AWS Network Firewall with a domain allow-list remove every internet path except named destinations. [Strategy: Outbound restrictions]
- Mutual TLS between services through Envoy or an ambient mesh closes the plain-HTTP gap inside the cluster. [Strategy: Internal encryption]

08 Avoid shared powerful accounts

- One Kubernetes service account per workload maps to one IAM role through EKS Pod Identity, scoped to its own secret and key. [Strategy: Workload identities]
- No application has a Role or RoleBinding, and token mounting is off. [Strategy: Workload identities]
- Separate database logins serve the public devices service, the geometry service, the admin backend and the Flyway migration job, with a non-login owner role. [Strategy: Database permissions]
- Named DBA roles use IAM authentication, and per-user secrets sit behind RDS Proxy. [Strategy: Database permissions]
- The master account is reserved for break-glass, with an alert on every login. [Strategy: Database anomaly alert]

09 Protect personal data across both providers

- The KMS, Secrets Manager, RDS, backup and retention controls are the same as the other packages. [Strategy: Data protection]
- Raw location samples are deleted 30 days after an event closes, and the device email field is removed. [Strategy: Data retention]
- Imperva must deliver logs to an S3 bucket in the home Region, confirmed before go-live. [Strategy: Imperva decision]
- The supplier register records the data processing agreement, residency commitment and security clauses the contract provides. [Strategy: Ownership and approvals]
- Any Imperva log or point-of-presence data held outside the approved territory is the residency drift risk the strategy lists, and needs explicit steering committee approval. [Strategy: Residency drift]

10 Enforce safe releases internally

- Hardened Temurin JRE images pinned by digest through an ECR pull-through cache, non-root with no debug agent, exactly as in Proposal 1. [Strategy: Container protection]
- Kyverno enforces cosign verification and a registry allow-list, and the SBOM, provenance, Trivy and Inspector gates stay. [Strategy: Secure delivery]
- Weekly rebuilds and vulnerability SLAs of 7, 30 and 90 days apply. [Strategy: Secure delivery]
- Pipeline SAST, dependency review, secret scanning and DAST, plus a tested Argo CD rollback, complete the release controls. [Strategy: Application security]

11 One response process across two vendors

- Imperva DDoS and attack notifications, AWS findings and application audit alerts share the same tiered SNS routing. [Strategy: Incident alerts]
- Imperva alerts are P2 and become P1 during an event or drill. [Strategy: Edge DDoS alert]

- Each runbook states how to contact each provider. [Strategy: Incident alerts]
- The signed static emergency page is cached at Imperva as the origin-failover target. [Strategy: Emergency fallback]
- The DDoS playbook includes Imperva escalation, AWS Shield and the event-mode scale profile, and a joint exercise with Imperva runs before each national exercise. [Strategy: Recovery]

12 Price the contract and the duplicate inspection

- Add the quoted Imperva service and support cost to about USD 489 per month for Verified Access. [Verified Access pricing]
- Add the AWS WAF web ACL at the origin, which inspects every request that passes Imperva, and the common detection, logging and backup allowances. [AWS WAF pricing]
- Compare that total and the migration avoided against Proposals 1 and 2, including traffic overages, contract commitments and incident support. [Strategy: Imperva decision]
- Replace the worksheet's placeholder with the actual contract figure before approval. [Strategy: Imperva decision]

13 What management must accept

- No new connector or jump server is required. [Strategy: Access options]
- The team operates the existing workloads and coordinates WAF rules, log delivery, residency evidence and incidents across AWS and Imperva. [Strategy: Responsibilities]
- The edge vendor sits in the supplier register with contract clauses and collected evidence. [Strategy: Ownership and approvals]
- Approve only when the contract, the tested protection including mandatory origin mutual TLS, and the migration savings justify the extra cost and coordination. [Strategy: Gate: origin accepts only the edge]

BUDGET WORKSHEET · INSIDE THIS PROPOSAL

Common costs + your chosen option

Every field starts with an editable estimate so you can compare Common plus each option immediately. These are **planning estimates, not approved budgets or vendor quotes**; clearing a field makes it unpriced, not free.

Simple planning assumptions

USD per month, 730 hours, at most 100 administrators, one web access application and two technical endpoints. Rates were checked on 22 October 2026 against Verified Access pricing and WAF pricing; confirm deployment-region rates before approval.

Public requests per month, in millions 10

Ten million requests is a comparison example, not a forecast from the administrator count or the emergency-user count. WAF examples assume one ACL and ten billable rule entries per inspected layer; advanced rules, challenges and extra inspection can cost more.

The basis notes explain the starting estimates; if you edit a field, they do not become a new quote or automatically change the assumed scope. Labour uses a planning rate of USD 100 per hour, and routine operations assume existing on-call coverage.

Common · pay once, whichever option you choose

Cost item	Monthly USD	Basis
Account safeguards	USD 0.00	Organizations has no additional service charge; configuration work is below.
Threat detection and security checks	USD 300.00	Planning allowance: GuardDuty 100 + Security Hub 100 + Inspector 50 + Config 50 per month; validate against actual account and workload usage. See usage pricing.
Logs, backups and other security usage	USD 250.00	Planning allowance: logs and retention 75 + backups 125 + keys, secrets and access usage 50 per month; validate storage growth and restore costs. See log pricing.
Ongoing security operations	USD 1,200.00	Planning allowance: 12 hours per month × USD 100 for reviews, patching and routine response; assumes an existing on-call team, not new 24/7 staffing.
Additional identity licences	USD 300.00	Planning allowance: 100 administrators × USD 3 per month for any additional identity licences; not a vendor price, and removable if existing licences suffice. IAM Identity Center itself has no extra charge.
Shared setup and security assessment · one-time USD Planning allowance: 40 hours × USD 100 for shared controls, plus USD 4,000 for penetration testing and retesting; replace with scoped estimates.		USD 8,000.00

Common priced subtotal: **USD 2,050.00 (estimate)** per month.

Proposal 1 · Lean AWS

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
Public web firewall	USD 21.00	USD 5 + ten rule entries + USD 0.60 per million public requests.
Implementation and testing for this option · one-time USD Planning allowance: 20 hours × USD 100 for access, firewall configuration and testing.		USD 2,000.00

Option-only priced subtotal: **USD 525.70 (estimate)** per month, before Common.

Proposal 2 · AWS edge

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
CloudFront package including public WAF	USD 200.00	Business plan example: USD 200; that plan does not list origin failover, which the edge-served emergency page needs, so expect the Premium plan or pay-as-you-go pricing and confirm features and traffic limits before choosing.
Implementation and testing for this option · one-time USD Planning allowance: 30 hours × USD 100 for access, edge configuration and testing.		USD 3,000.00

Option-only priced subtotal: **USD 704.70 (estimate)** per month, before Common.

Proposal 2 counts public WAF inside the example CloudFront package, not again as a separate charge. If choosing pay-as-you-go instead, enter the combined CDN and public WAF estimate in that field.

Proposal 3 · Existing edge

Cost item	Monthly USD	Basis
Verified Access web application	USD 197.10	730 hours × USD 0.27; private administrator website.
Verified Access technical connections	USD 292.00	Two endpoints × 730 hours × USD 0.20; cluster and database.
Administrator web firewall	USD 15.60	One ACL, ten billable rule entries, one million requests.
AWS firewall at the public origin	USD 21.00	Conservative example: all entered public requests reach this inspection layer.
Imperva service and support	USD 1,000.00	Planning placeholder: USD 1,000 per month for service and support, not an Imperva quote; replace with the actual contract cost.
Implementation and testing for this option · one-time USD Planning allowance: 30 hours × USD 100 for access, vendor integration and testing.		USD 3,000.00

Option-only priced subtotal: **USD 1,525.70 (estimate)** per month, before Common.

Decision total

Common + Proposal 1: USD 2,575.70 (estimate) per month. First year, including one-time costs: USD 40,908.40 (estimate).

Common + option	Monthly	Yearly recurring	One-time
Proposal 1	USD 2,575.70 (estimate)	USD 30,908.40 (estimate)	USD 10,000.00 (estimate)
Proposal 2	USD 2,754.70 (estimate)	USD 33,056.40 (estimate)	USD 11,000.00 (estimate)
Proposal 3	USD 3,575.70 (estimate)	USD 42,908.40 (estimate)	USD 11,000.00 (estimate)

Totals are incremental security planning estimates, not a full website-running-cost quote. Existing application hosting, load balancers, database and cluster capacity, taxes and general internet delivery are excluded unless explicitly included in a package; do not count the same cost twice.

The Common usage allowance includes a starter amount for access data processing and connection charges; increase it when usage is known. Confirm licences, emergency capacity, retention volumes, support and migration scope before approval; the estimate includes no contingency or separately purchased 24/7 response service.

MANAGEMENT PREPARATION

Questions and answers worksheet

A separate, self-contained worksheet with 50 detailed Q&As covering the Common foundation, administrator access, all three options, internal controls and budget qualifications. Use it during management discussions without needing the full proposal open.

Read the

Q&A worksheet

, or download its separate

Markdown

and

PDF

.

The worksheet exports contain only the Q&As, not the full proposal. Cost answers use the saved starting estimates, not unsaved browser edits, and identify gaps that must be resolved before budget approval.